

WHOIS

WHOIS is a query/response protocol used to look up registration information for domain names and IP address blocks. It's one of the oldest and most fundamental **passive reconnaissance** tools — mapping directly to the Reconnaissance stage of the Kill Chain and MITRE ATT&CK's Reconnaissance tactic (specifically **T1596.002 — Search Open Technical Databases: WHOIS**).

1. What WHOIS Actually Tells You

When you query a domain, WHOIS returns data from the domain's **registrar** and **registry**, typically including:

- **Registrant info** — who registered the domain (often redacted now, more on this below)
- **Registrar** — the company the domain was registered through (GoDaddy, Namecheap, etc.)
- **Creation / Updated / Expiration dates**
- **Name servers (NS records)** — which DNS servers are authoritative for the domain
- **Domain status codes** — e.g., `clientTransferProhibited`
- **Admin/Tech contact info** — historically included emails/phone numbers, now mostly redacted

For **IP addresses**, WHOIS returns different info entirely:

- **Regional Internet Registry (RIR)** — ARIN, RIPE, APNIC, LACNIC, AFRINIC
 - **Organization/ISP that owns the IP block**
 - **CIDR range** the IP belongs to
 - **Abuse contact email** — very useful for incident response/reporting
-

2. Basic Usage

Command line (Linux/Kali — pre-installed):

```
whois example.com
```

Sample output (domain):

```
Domain Name: EXAMPLE.COM
Registrar: RESERVED-Internet Assigned Numbers Authority
Creation Date: 1995-08-14T04:00:00Z
Registry Expiry Date: 2026-08-13T04:00:00Z
Name Server: A.IANA-SERVERS.NET
Name Server: B.IANA-SERVERS.NET
Domain Status: clientDeleteProhibited
Domain Status: clientTransferProhibited
```

Querying an IP address instead of a domain:

```
whois 8.8.8.8
```

```
NetRange:      8.0.0.0 - 8.127.255.255
CIDR:          8.0.0.0/9
OrgName:       Level 3 Parent, LLC
OrgAbuseEmail: abuse@level3.com
```

3. Why Registrant Data Often Looks Empty Now — WHOIS Privacy & GDPR

This is a commonly misunderstood but important point for anyone studying this today.

Before ~2018, `whois` on any domain often revealed the actual registrant's name, email, phone, and address directly. Two things changed that:

a) WHOIS Privacy / Domain Privacy services — registrars (GoDaddy, Namecheap, etc.) let owners pay for a proxy service that replaces their real info with the registrar's own placeholder data.

b) GDPR (2018) — after GDPR, ICANN mandated that registrars **redact personal data** for domains tied to EU registrants (and most registrars now apply this globally by default to avoid liability). This is why most modern `whois` output looks like:

```
Registrant Organization: REDACTED FOR PRIVACY  
Registrant Email: Please query the RDDS service of the Registrar of Record...
```

What this means practically for recon: WHOIS is now much less useful for *directly* identifying a person than it was a decade ago — but it's still valuable for **infrastructure mapping** (registrar, name servers, creation date, IP ownership), which is often more useful for pentesting anyway.

4. Practical Recon Use Cases

a) Identifying the Registrar and Name Servers (infrastructure fingerprinting)

```
whois example.com | grep -i "registrar\|name server"
```

Knowing the name servers tells you if a target uses Cloudflare, AWS Route53, GoDaddy DNS, etc. — useful context before deeper DNS enumeration.

b) Finding the Hosting Provider / ASN via IP WHOIS

```
whois 93.184.216.34
```

This reveals which ISP/hosting provider owns the IP block — useful for understanding whether a target is self-hosted, on a cloud provider (AWS/Azure/GCP), or behind a CDN.

c) Correlating Domain Creation Date with Phishing/Threat Intel

```
whois suspicious-domain.com | grep -i "creation date"
```

A huge real-world use case: domains registered very recently (days or weeks ago) are a strong phishing/malicious-infrastructure indicator. SOC analysts and threat intel teams routinely check domain age as part of triaging a suspicious URL — a domain that's 3 days old pretending to be "paypal-secure-login.com" is an immediate red flag, whereas a domain registered 15 years ago carries much less inherent suspicion.

d) Finding Related/Sibling Domains (historical technique, now more limited)

Historically, if a registrant's real email/name was visible, you could search **reverse WHOIS** databases to find every other domain registered with that same email — useful for mapping an organization's full external footprint (subsidiaries, shadow IT, forgotten domains). This is much less effective post-GDPR-redaction but still works for domains that haven't enabled privacy protection, and reverse WHOIS services still index historical (pre-redaction) records.

e) Checking Domain Expiration (relevant to both attackers and defenders)

```
whois example.com | grep -i "expiry\|expiration"
```

Expired domains can sometimes be re-registered by attackers to hijack residual trust (old backlinks, forgotten SPF/DKIM records, abandoned subdomains still pointing to the expired domain) — a technique sometimes called "domain resurrection."

5. Bulk / Automated WHOIS Lookups (How It's Used at Scale)

Manually running `whois` one domain at a time doesn't scale for real engagements — a few common approaches:

```
# Loop through a list of domains
for domain in $(cat domains.txt); do
    echo "=== $domain ==="
    whois $domain | grep -i "creation date\|registrar\|name
server"
done
```

Python (whois library) — often embedded into larger recon scripts:

```
import whois

result = whois.whois("example.com")
```

```
print(result.registrar)
print(result.creation_date)
print(result.name_servers)
```

This is exactly the kind of Python integration you already used in SmartScan with the NVD CVE API — same pattern, different data source.

6. Web-Based WHOIS Tools (Alternatives to CLI)

Useful when `whois` isn't installed, or when you want a cleaner formatted view:

- **whois.domaintools.com** — also shows historical WHOIS records (very useful, since it can reveal pre-redaction data from before GDPR/privacy services were enabled)
- **who.is**
- **ICANN Lookup (lookup.icann.org)** — official, standardized ICANN interface
- **RIPE, ARIN, APNIC databases directly** — for deep IP/ASN research beyond what generic `whois` clients show

Historical WHOIS is worth calling out specifically — services like DomainTools' history feature let you see what a domain's WHOIS record looked like *years ago*, sometimes before the owner enabled privacy protection, which can occasionally still reveal real registrant info from before 2018.

7. WHOIS in the Broader Recon Workflow

WHOIS is rarely used alone — it's typically the **first step** in a chain:

```
WHOIS (registrar, NS, IP)
↓
DNS enumeration (dig, nslookup, dnsrecon)
↓
Subdomain enumeration (Sublist3r, Amass, subfinder)
↓
Port scanning identified IPs (Nmap)
↓
Service/version detection → vulnerability mapping
```

This is exactly the recon-to-exploitation pipeline you'd document in a VAPT report's methodology section — WHOIS gives you the starting infrastructure

map before you touch anything active.

8. WHOIS vs. Other Recon Tools — Quick Distinction

Tool	What It Reveals
WHOIS	Domain/IP registration info, registrar, name servers, dates
DNS lookup (<code>dig</code> / <code>nslookup</code>)	Actual DNS records (A, MX, TXT, NS) — what the domain resolves to
Google Dorking	Indexed content, exposed files, misconfigurations
theHarvester	Emails, subdomains, employee names from multiple OSINT sources
Shodan/Censys	Internet-wide scanning data — open ports/services on an IP, regardless of domain

WHOIS answers "**who owns this and through whom?**" — DNS tools answer "**what does this actually point to?**" — they're complementary, not overlapping.

9. Legal & Ethical Notes

- Querying WHOIS is **completely legal** — it's a public lookup protocol, explicitly designed for this purpose by ICANN/registries
- **No authorization needed** to run WHOIS lookups, unlike active scanning (Nmap) against a target's live infrastructure — this is why it's always one of the very first, zero-risk steps in any engagement
- The main ethical consideration isn't the lookup itself, but **what you do with any data found** — e.g., if an old/unredacted WHOIS record reveals a personal email or phone number, using that for social engineering without authorization crosses into unauthorized/unethical territory even though the lookup itself was legitimate

Quick Reference Cheat Sheet

```
whois example.com # domain lookup
whois 8.8.8.8 # IP lookup
whois example.com | grep -i "registrar" # extract registrar
```

```
gistrar
whois example.com | grep -i "name server"      # extract NS
records
whois example.com | grep -i "creation date"     # check doma
in age

# Bulk lookup
for d in $(cat domains.txt); do whois $d | grep -i "registr
ar"; done
```

```
import whois
w = whois.whois("example.com")
print(w.creation_date, w.registrar, w.name_servers)
```